

Security program management and oversight (20%)

5.1 Security Governance

Guidelines – Recommended (not mandatory) best practices; flexible direction for decision-making

Policies – Mandatory rules the organization must follow:

- **AUP (Acceptable Use Policy)** – Defines allowed and prohibited use of org systems
- **Information security policy** – Overarching rules for protecting data and systems
- **Business continuity** – How the org maintains operations during a disruption
- **Disaster recovery** – How the org restores IT systems after a major incident
- **Incident response** – Steps to detect, contain, and recover from security events
- **SDLC (Software Development Lifecycle)** – Security requirements embedded into development phases
- **Change management** – Formal process for making changes to IT systems

Standards – Specific mandatory requirements that implement policies:

- **Password** – Minimum length, complexity, expiration rules
- **Access control** – How permissions are assigned, reviewed, and revoked
- **Physical security** – Badge requirements, visitor escort, clean desk
- **Encryption** – Algorithm and key length requirements for data at rest and in transit

Procedures – Step-by-step instructions for carrying out specific tasks:

- **Change management** – How to submit, review, approve, and implement changes
- **Onboarding/Offboarding** – Account provisioning and access removal workflows

- **Playbooks** – Specific response procedures for defined incident types

External Considerations

- **Regulatory** – Laws and regulations that mandate specific security controls
- **Legal** – Contractual obligations, liability, attorney-client privilege
- **Industry** – Sector-specific standards (PCI DSS for payments, HIPAA for healthcare)
- **Local/National/Global** – Jurisdiction affects what laws apply to data and operations

Monitoring and Revision – Governance documents must be reviewed regularly and updated as threats, regulations, and business needs change

Types of Governance Structures

- **Boards** – Executive-level oversight; set risk appetite and strategic direction
- **Committees** – Cross-functional groups (security steering committee)
- **Government entities** – Regulatory bodies that oversee compliance
- **Centralized** – Single authority sets policy for the entire org; consistent but less agile
- **Decentralized** – Business units set their own policy; flexible but harder to enforce uniformly

Roles and Responsibilities

- **Owner** – Accountable for the data/system; approves access and accepts risk
- **Controller** – Determines the purpose and means of data processing (GDPR term)
- **Processor** – Processes data on behalf of the controller (e.g., a third-party vendor)
- **Custodian/Steward** – Day-to-day management of data; enforces owner's policies

5.2 Risk Management

Risk Identification – Find all assets, threats, and vulnerabilities that could result in loss

Risk Assessment

- **Ad hoc** – Unscheduled; triggered by a specific event or concern
- **Recurring** – On a regular schedule (annual, quarterly)
- **One-time** – For a specific project or system change
- **Continuous** – Ongoing automated monitoring and assessment

Risk Analysis

- **Qualitative** – Descriptive ratings (High / Medium / Low); based on judgment
- **Quantitative** – Dollar-value calculations; more precise but requires reliable data
- **SLE (Single Loss Expectancy)** – $\text{Asset Value} \times \text{Exposure Factor}$; cost of one loss event
- **ALE (Annualized Loss Expectancy)** – $\text{SLE} \times \text{ARO}$; expected yearly loss
- **ARO (Annualized Rate of Occurrence)** – How many times per year the event is expected
- **Probability** – Likelihood that a threat will materialize
- **Likelihood** – Similar to probability; often used in qualitative assessments
- **Exposure factor** – Percentage of asset value lost in one incident
- **Impact** – Magnitude of harm if the risk materializes

Risk Register – Centralized list documenting all identified risks with owner, rating, and status

- **Key risk indicators (KRIs)** – Metrics that signal rising risk before an incident occurs
- **Risk owners** – Person responsible for monitoring and treating a specific risk
- **Risk threshold** – The point at which a risk requires escalation or action

Risk Tolerance – Maximum acceptable level of risk an org is willing to operate under

Risk Appetite

- **Expansionary** – Willing to accept more risk to pursue growth and opportunity
- **Conservative** – Minimizes risk; prefers proven, low-risk approaches

- **Neutral** – Balanced; risk accepted proportional to potential reward

Risk Management Strategies

- **Transfer** – Shift financial impact to a third party (cyber insurance, contracts)
- **Accept** – Acknowledge the risk and choose to operate without additional controls
 - **Exemption** – Permanent acceptance; risk owner formally approves
 - **Exception** – Temporary acceptance; time-limited with a remediation plan
- **Avoid** – Eliminate the activity that creates the risk
- **Mitigate** – Apply controls to reduce likelihood or impact

Risk Reporting – Communicate risk posture to leadership and stakeholders regularly

Business Impact Analysis (BIA)

- **RTO (Recovery Time Objective)** – Maximum acceptable downtime before business is harmed
- **RPO (Recovery Point Objective)** – Maximum acceptable data loss measured in time
- **MTTR (Mean Time to Repair)** – Average time to restore a failed system or service
- **MTBF (Mean Time Between Failures)** – Average time a system runs before the next failure

5.3 Third-Party Risk Assessment & Management

Vendor Assessment

- **Penetration testing** – Test the vendor's environment for exploitable weaknesses
- **Right-to-audit clause** – Contract provision allowing you to audit the vendor's security controls
- **Evidence of internal audits** – Request vendor's own audit reports (SOC 2, ISO 27001)

- **Independent assessments** – Third-party reviews of the vendor (not self-reported)
- **Supply chain analysis** – Trace all components back through the vendor's suppliers

Vendor Selection

- **Due diligence** – Thorough security review before signing a contract
- **Conflict of interest** – Ensure the selection process is unbiased

Agreement Types

- **SLA (Service-Level Agreement)** – Defines uptime, performance, and support commitments
- **MOA (Memorandum of Agreement)** – Formal intent to work together; more binding than MOU
- **MOU (Memorandum of Understanding)** – High-level informal agreement on shared goals
- **MSA (Master Service Agreement)** – Umbrella contract covering the overall relationship
- **SOW (Statement of Work)** – Specific deliverables, timelines, and costs for a project
- **NDA (Non-Disclosure Agreement)** – Protects confidential information shared between parties
- **BPA (Business Partners Agreement)** – Defines responsibilities when two orgs share resources

Vendor Monitoring – Continuously review vendor security posture throughout the relationship

Questionnaires – Standardized security assessments sent to vendors (SIG, CAIQ)

Rules of Engagement – Define how penetration testers or assessors may interact with vendor systems

5.4 Security Compliance

Compliance Reporting

- **Internal** – Reports to leadership on control effectiveness and gaps

- **External** – Reports to regulators, auditors, or customers

Consequences of Non-Compliance

- **Fines** – Monetary penalties imposed by regulators (GDPR: up to 4% global revenue)
- **Sanctions** – Restrictions on business operations
- **Reputational damage** – Loss of customer trust; lasting brand harm
- **Loss of license** – Revocation of ability to operate (financial, healthcare sectors)
- **Contractual impacts** – Breach of contract clauses; termination; liability

Compliance Monitoring

- **Due diligence/care** – Ongoing effort to identify and address compliance gaps
- **Attestation and acknowledgement** – Formal sign-off that controls are in place
- **Internal and external** – Both self-assessments and independent reviews required
- **Automation** – Tools that continuously check configuration against compliance baselines

Privacy

- **Legal implications** – Privacy laws vary by jurisdiction (GDPR, CCPA, HIPAA)
- **Data subject** – The individual whose personal data is being processed
- **Controller vs. processor** – Controller decides why data is collected; processor handles it
- **Ownership** – Who is legally responsible for the data
- **Data inventory and retention** – Know what you have, where it is, and how long to keep it
- **Right to be forgotten** – GDPR right for individuals to request deletion of their data

5.5 Audits & Assessments

Attestation – Formal statement by an authorized party that controls are operating as intended

Internal Audits

- **Compliance** – Verify that the org meets regulatory and policy requirements
- **Audit committee** – Oversight body that reviews audit findings and ensures independence
- **Self-assessments** – Departments evaluate their own adherence to policies

External Audits

- **Regulatory** – Required by law or regulation (banking, healthcare, public companies)
- **Examinations** – Regulatory body directly inspects the organization
- **Assessment** – External review of a specific system, process, or control set
- **Independent third-party audit** – Unbiased review; provides highest credibility (SOC 2, ISO 27001)

Penetration Testing

- **Physical** – Attempt to bypass physical security (lock picking, tailgating)
- **Offensive** – Red team; simulate a real attacker to find exploitable weaknesses
- **Defensive** – Blue team; detect and respond to simulated attack activity
- **Integrated** – Red + blue (purple team); collaborative attack/defend exercise
- **Known environment (white box)** – Tester has full knowledge of architecture and systems
- **Partially known (grey box)** – Tester has some knowledge; simulates an insider or vendor
- **Unknown environment (black box)** – Tester has no prior knowledge; simulates external attacker

Reconnaissance

- **Passive** – Gather info without touching the target (OSINT, WHOIS, LinkedIn)
- **Active** – Directly probe the target (port scanning, service enumeration); leaves traces

5.6 Security Awareness Practices

Phishing

- **Campaigns** – Simulated phishing emails sent to employees to test susceptibility
- **Recognizing a phishing attempt** – Urgency, mismatched sender, unexpected links or attachments
- **Responding to suspicious messages** – Report to security team; do not click; do not forward

Anomalous Behavior Recognition – Train users to identify and report unusual activity:

- **Risky** – Actions that violate policy (USB use, shadow IT, sharing credentials)
- **Unexpected** – Out-of-character behavior (large data download, off-hours access)
- **Unintentional** – Accidental policy violations; still need to be reported

User Guidance & Training

- **Policy/handbooks** – Clear documentation of acceptable behavior and consequences
- **Situational awareness** – Train staff to notice and question what seems out of place
- **Insider threat** – Recognize behaviors that may indicate malicious or compromised insiders
- **Password management** – Use a password manager; never reuse or share passwords
- **Removable media and cables** – Never plug in unknown USB devices or cables
- **Social engineering** – Recognize pretexting, urgency, authority, and impersonation tactics
- **Operational security (OPSEC)** – Don't share sensitive info in public or on social media
- **Hybrid/remote work** – Use VPN; avoid public Wi-Fi; lock screens; beware shoulder surfing

Reporting and Monitoring

- **Initial** – Baseline training for all new employees at onboarding
- **Recurring** – Annual or more frequent refreshers; updated for emerging threats

Development – Design awareness programs based on risk assessment and past incidents

Execution – Deliver training through varied formats (video, phishing simulations, in-person); measure effectiveness through click rates, quiz scores, and reported incidents